

SAT 3812: Cyber Security I

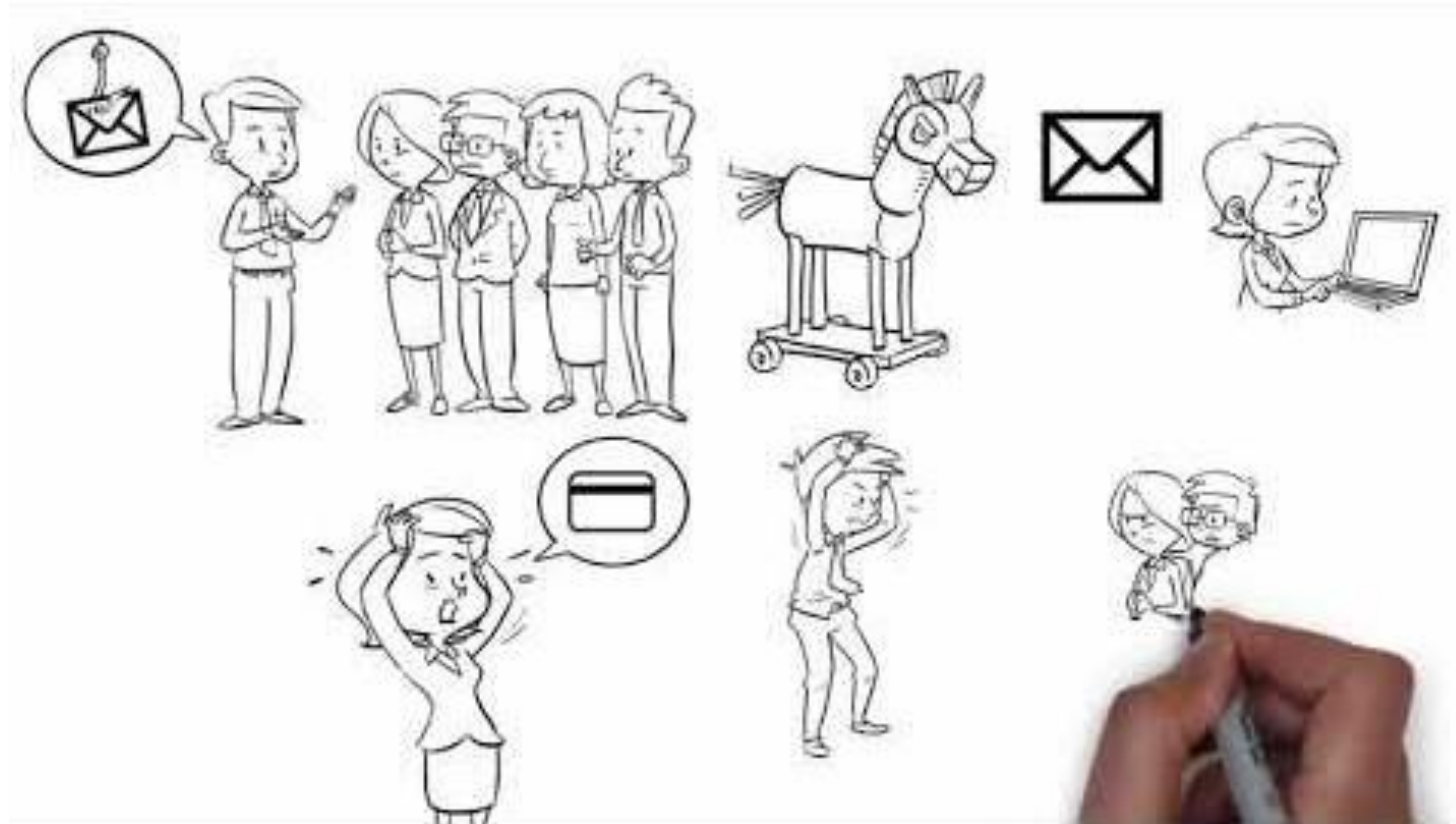
Email Security

Instructor: Yunlong Xing



What is Email Phishing?

<https://www.youtube.com/watch?v=Y7zNIEMDmI4>



A real phishing email example

From: Tian-Bai@mtu.edu <tbai@mtu.edu>

Date: 2017-02-07 6:38 GMT+08:00

Subject: Services-Desk

To:

Michigan IT team at MTU has suggested a solution to secure your Account. A reform will be made in our MTU mail, because it seems here are multiple users we like to be sure of these users and as a result you will have to submit your MTU details immediately you receive this mail.

Use this link to secure your account now. mtu-edu-it.myfreesites.net/

Your account is at risk, please followed the instructions to avoid disabling your account.

Michigan Technological University.

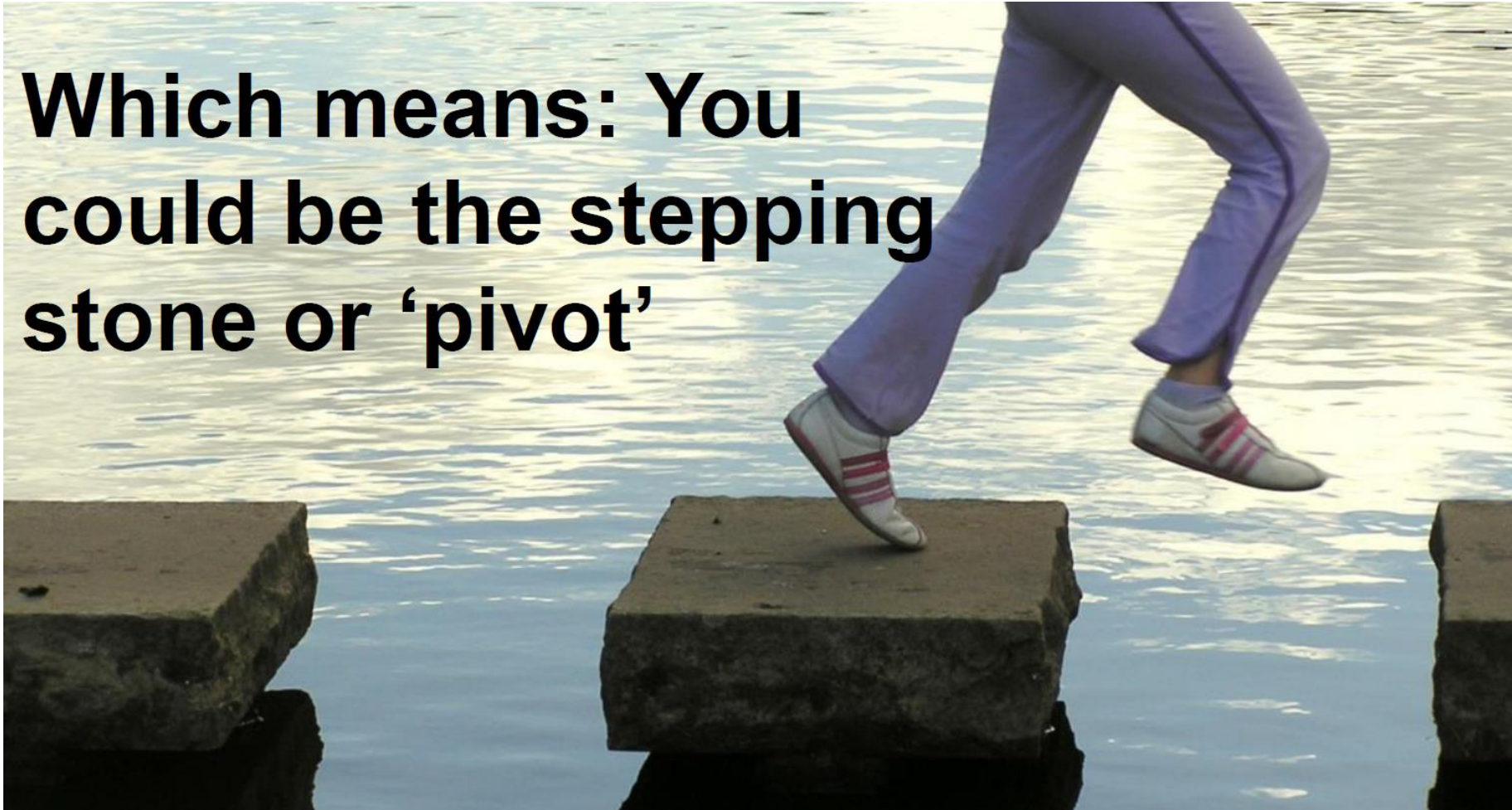
A small percentage of phishing emails bypassed the email filters.

Why is Phishing Email so Dangerous?

- Most people don't receive enough training to tell whether an email is phishing or not.
- 91% Of Cyberattacks Nowadays Start With A Phishing Email
- 70% of phishing attacks lead to a secondary target
 - You are just a stepping stone!

Source: [<http://www.darkreading.com/endpoint/91--of-cyberattacks-start-with-a-phishing-email/d/d-id/1327704>]

**Which means: You
could be the stepping
stone or ‘pivot’**



Why is Email so Dangerous?

- See what happened in the President election in 2016
 - Hillary Clinton email controversy
 - DNC (Democratic National Committee) email leak
 - Wikileaks

Phishing & Social Engineering

Only amateurs attack machines; professionals target people.

- We've evolved thousands of years to deal with deception in face-to-face contexts, but too short for online security.
- Hoaxes and frauds always happened, but the Internet makes things easier.
- New attacks comes with new technology: phishing, pretexting....

How difficult to send a phishing email?

- EASY!
- Skills needed:
 - Basic understanding of Web, Email and Internet
 - Basic HTML
 - Basic PHP
 - Be creative!
 - Be patient!

Design Flaws of Emails

- Emails were designed back in 1970s.
 - At that time, the goal is to get things work, not to get things secured.
- Anyone can send out emails using any from addresses and any content
 - No authentication, no verification, no questions asked
 - Mimic real-world mails
 - But the cyber world is different

How to send phishing emails?

Many solutions

- Method 1: Register a domain and build/host your own email server, then you have full control of the email server.
- Method 2: Use php mail function. – Amazingly simple!
- Method 3: Use Python or other scripts.

Use PHP to send phishing emails

Here is the PHP code:

```
<?php  
mail('cai@mtu.edu',  
    'You are selected for the Presidential Award!',  
    'Please call us at the White House',  
    'From: biden@whitehouse.gov');  
?>
```

Syntax:

```
mail(to, subject, message, headers);  
headers is 'From: biden@whitehouse.gov'
```

Most PHP web servers will send the emails as instructed!

Screenshot

Your account is hacked!  Inbox x



president@whitehouse.gov

to me ▼

Please send us \$1000 to rescue your account!

This is a phishing email for education purpose only.

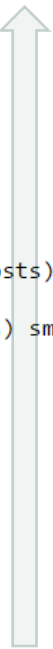
 Reply

 Forward

Original message / email header

```
Delivered-To: cai@mtu.edu
Received: by 10.202.212.129 with SMTP id l123csp707034oig;
      Wed, 1 Apr 2015 10:25:09 -0700 (PDT)
X-Received: by 10.236.38.132 with SMTP id a4mr45268617yhb.183.1427909109471;
      Wed, 01 Apr 2015 10:25:09 -0700 (PDT)
Return-Path: <a7701770@srv22.000webhost.com>
Received: from postlady.000webhost.com (postlady.000webhost.com. [31.170.163.253])
      by mx.google.com with ESMTP id f41si1239244yha.53.2015.04.01.10.25.08
      for <cai@mtu.edu>;
      Wed, 01 Apr 2015 10:25:09 -0700 (PDT)
Received-SPF: none (google.com: a7701770@srv22.000webhost.com does not designate permitted sender hosts) client-ip=31.170.163.253;
Authentication-Results: mx.google.com;
      spf=none (google.com: a7701770@srv22.000webhost.com does not designate permitted sender hosts) smtp.mail=a7701770@srv22.000webhost.com
Received: by postlady.000webhost.com ([000webhost.com Mail Server], from userid 99)
      id B4B1E602B4; Wed, 1 Apr 2015 13:25:08 -0400 (EDT)
X-Spam-Checker-Version: SpamAssassin 3.3.2 (2011-06-06) on
      postlady.000webhost.com
X-Spam-Level: *
X-Spam-Status: No, score=1.3 required=7.0 tests=RDNS_NONE,
      TVD_RCVD_SPACE_BRACKET autolearn=disabled version=3.3.2
Received: from srv22.000webhost.com (unknown [31.170.163.70])
      by postlady.000webhost.com ([000webhost.com Mail Server]) with ESMTP id C82FB6029C
      for <cai@mtu.edu>; Wed, 1 Apr 2015 13:25:01 -0400 (EDT)
Received: by srv22.000webhost.com (Postfix, from userid 7701770)
      id C166E39342; Wed, 1 Apr 2015 13:25:01 -0400 (EDT)
To: cai@mtu.edu
Subject: your account is hacked
X-PHP-Script: email.comoj.com/email.php for 97.88.40.55
From: obama@whitehouse.gov
Message-Id: <20150401172501.C166E39342@srv22.000webhost.com>
Date: Wed, 1 Apr 2015 13:25:01 -0400 (EDT)

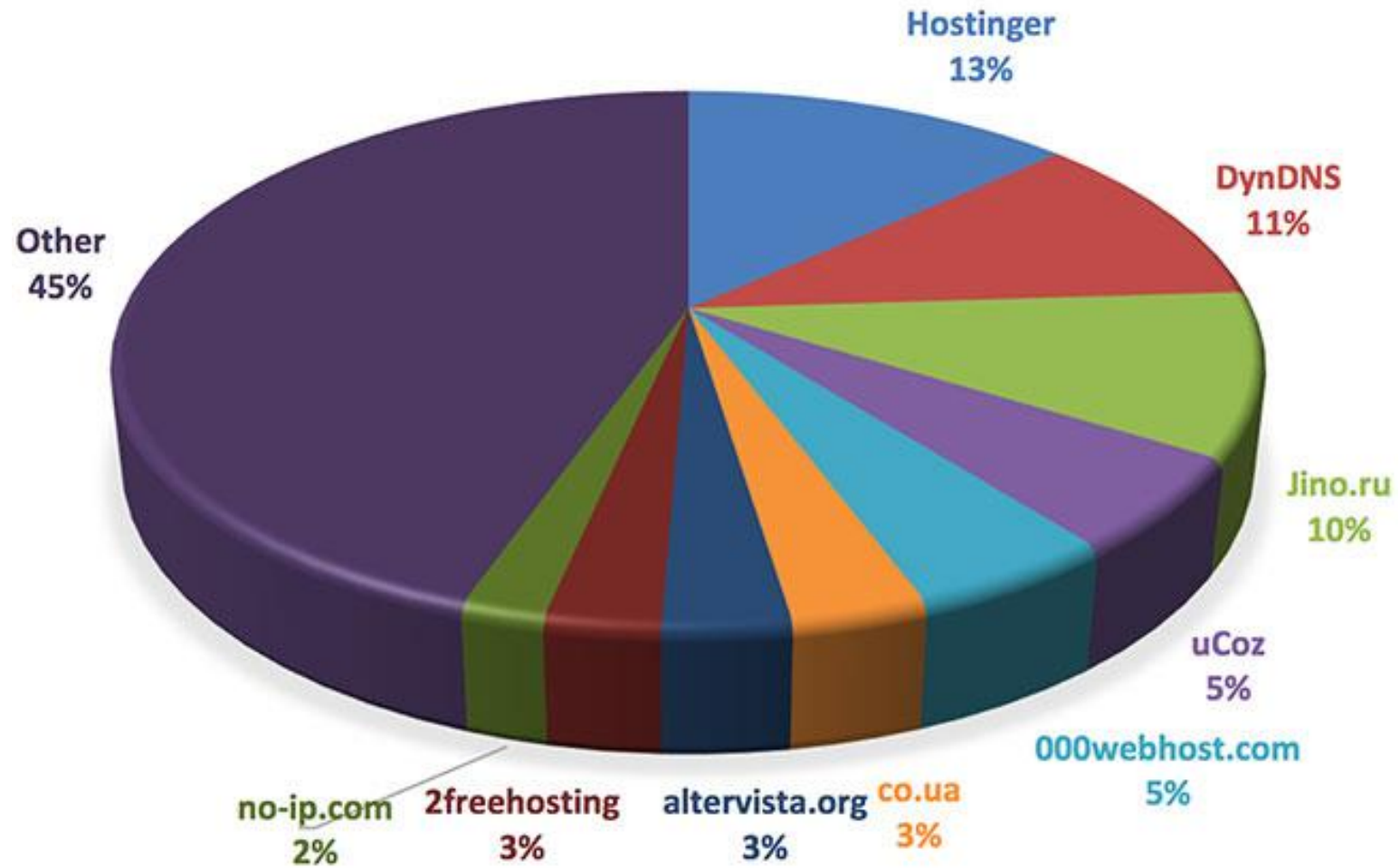
please call us
```



Read received from
bottom up

**Say one day you get a phishing email, please explain how you can trace back to the sender?
And how far can you trace back?**

TOP SUBDOMAIN SERVICES USED FOR PHISHING, 2016



Phishing Domains by TLD, 4Q2016

October		November		December	
.com	6,317	.com	6,757	.com	6,579
.net	596	.net	604	.net	523
.org	570	.org	577	.tk	484
com.br	430	com.br	426	.org	432
.ru	349	.info	350	.info	398
IP addresses	218	.ru	349	com.br	315
.info	216	.tk	345	.top	310
com.ve	200	.ga	314	.ga	302
co.uk	189	.ml	227	.cf	300
.online	168	IP addresses	226	.ml	298
other TLDs	4,359	other TLDs	4,652	other TLDs	4,843
TOTAL	13,612		14,827		14,784

How about <http://www.mtuedu.ml> or <http://www.mtuedu.online> ?

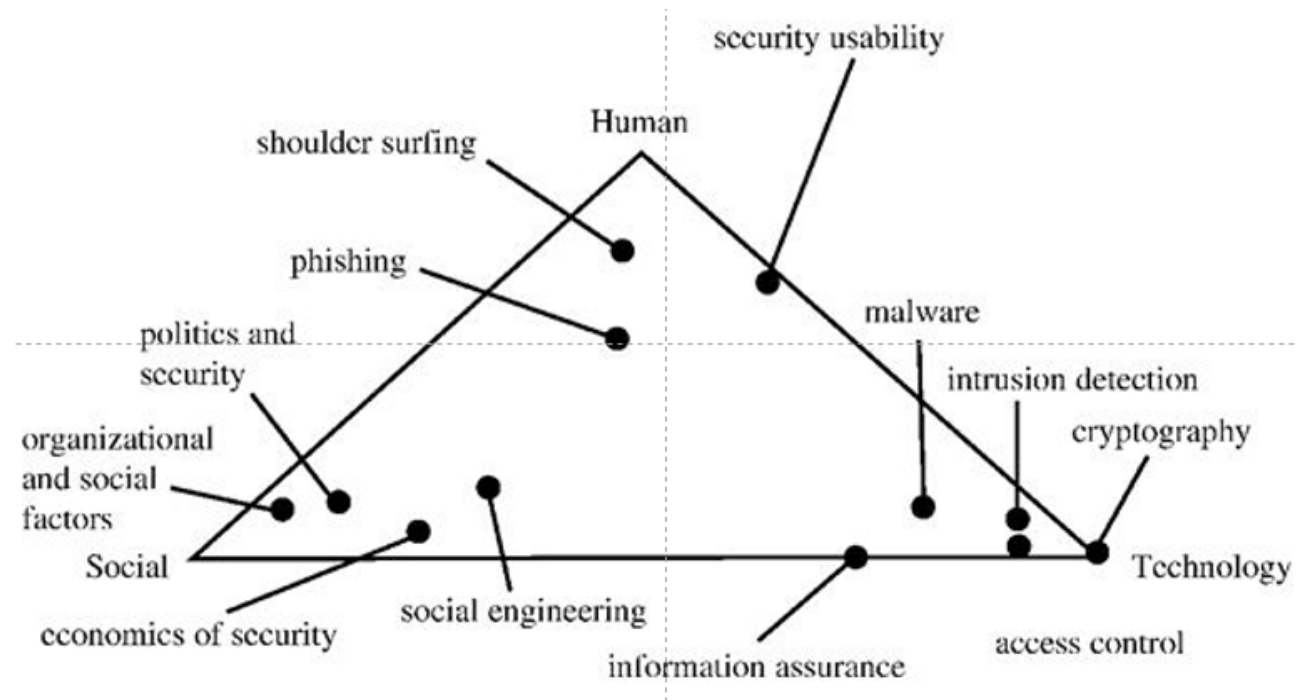
What is Social Engineering

<https://www.youtube.com/watch?v=Vo1urF6S4u0>



“Social Engineering”?

All Social Engineering techniques are based on flaws in human logic known as cognitive biases.



Phishing Schemes

- **context-aware spear phishing**
 - Spear: Specifically target at a small group of people!
 - For example, contractors with less IT training, or managers with high privileges...
 - Why? Bypass email filters; Avoid raising security alerts; High success rate
 - Context-aware: Email content are well-in-context, nothing suspicious!
 - For example, a fake canvas email
 - Hackers can collect some related information from public websites and social medias.

Amazon Sign In

Not secure | pages.mtu.edu/~cai/temp/amazon_login.html

amazon

Sign in

Email (phone for mobile accounts)

Password [Forgot your password?](#)

Sign in

☐ Keep me signed in. [Details](#)

New to Amazon?

Create your Amazon account

[Conditions of Use](#) [Privacy Notice](#) [Help](#)

© 1996-2017, Amazon.com, Inc. or its affiliates

This is a fake Amazon login page for education purpose only!

Detection by browser



Phishing attack ahead

Attackers on **www.tech.mtu.edu** might try to trick you to steal your information (for example, passwords, messages, or credit cards).

☒ Automatically report details of possible security incidents to Google. [Privacy policy](#)

[Hide details](#) [Back to safety](#)

Google Safe Browsing recently detected phishing on [www.tech.mtu.edu](#). [Phishing sites](#) pretend to be other websites to trick you.

If you understand the risks to your security, you may [visit this infected site](#).

Python Email Phishing

- Python includes several modules in the standard library for working with emails and email servers.
 - smtplib
 - email
- You will need to configure an email server or use an existing email account (like gmail)

Python Email Example 1

```
import smtplib
server = smtplib.SMTP('smtp.gmail.com', 587)

#Next, log in to the server
server.login("youremailusername", "yourpassword")

#Send the mail
msg = "
Hello!" # The /n separates the message from the headers
server.sendmail("you@gmail.com", "target@test.com", msg)
```

How to Stop Email Phishing?

■ Training & Education

- Email is “ok” for daily, non-sensitive communication.
- It is incredibly easy to forge an email which looks exactly like an legitimate one!
- It is possible to fool and bypass the email filters and other email security measures!
- Be careful when opening email attachments
- Be careful when clicking links in emails
 - If you have to, double check the URL!

Click links or not?

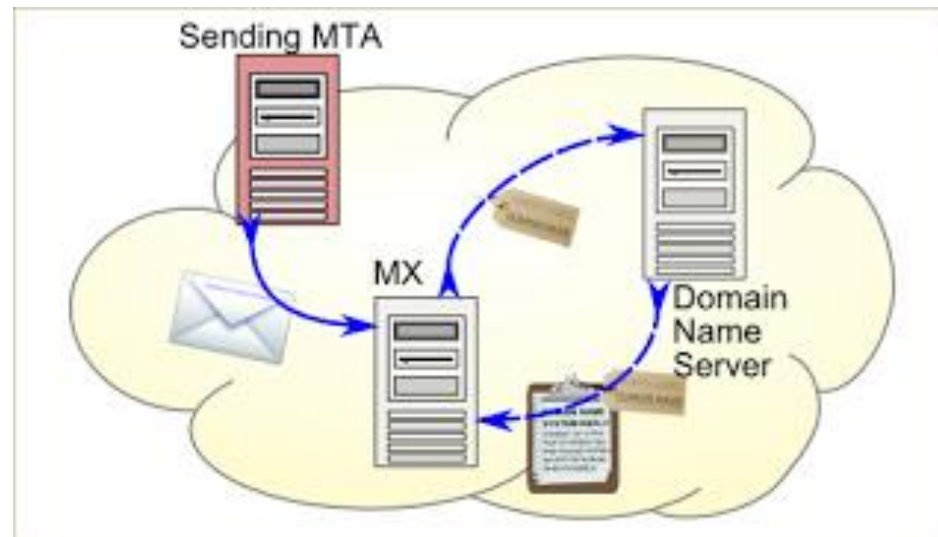
- Ironically, IT security people keep telling you: “Don’t click links in emails”, but IT industry keep sending out emails with links.
- A lot of misleading and conflicting phishing information everywhere

How to Stop Email Phishing?

- Many phishing education software
 - Gophish or phishme
 - Launch phishing campaigns to educate your users.
- Email filter + website filter + browser filter
 - Smart filter with deep learning
 - Phishing alert

How to Stop Email Phishing?

- SPF, DKIM and DMARC
 - SPF (Sender Policy Framework) is a DNS text entry which shows a list of servers that should be considered allowed to send mail for a specific domain.

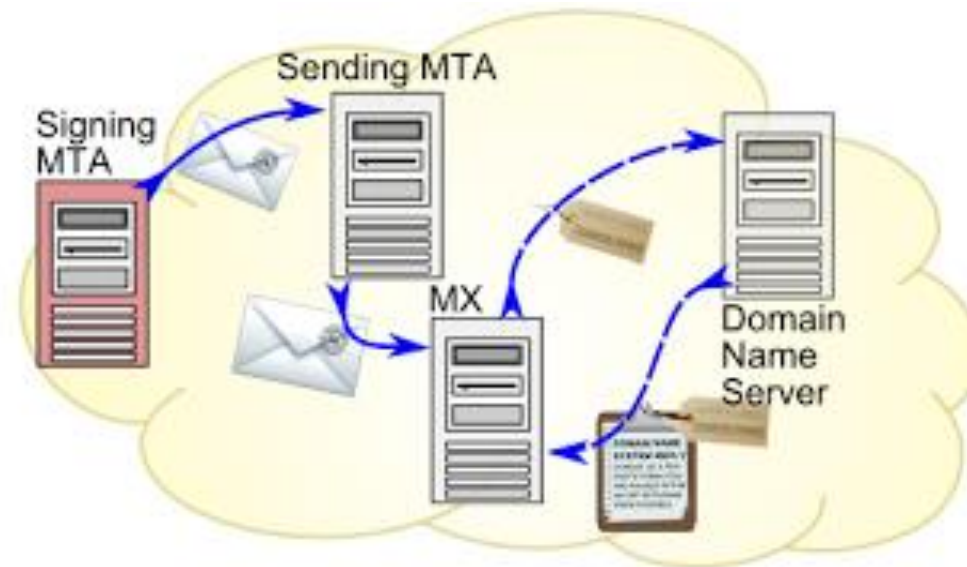


A Little More SPF Syntax

- Here's a real example:
`mtu.edu TXT "v=spf1 ip4:141.219.0.0/16 include:_spf.google.com include:_spf.mtu.edu include:emailsrvr.com ~all"`
- The `ip4` field is where you specify the addresses that are acceptable sources (obviously for IPv4 address only).
- The `include` indicates that there are other domains that might be sending email on our behalf. A full verification needs to validate the SPF entries at those domains as well.
- The `~` character means that whatever follows *should* be okay, but needs to be marked for closer inspection.
 - So `~all` means it's possible that an `@mtu.edu` email could come from any IP address in the world. It's up to the receiver to decide what to do with this.
 - A restrictive policy would reject the email. A more permissive policy might put it in a Junk Mail folder.

How to Stop Email Phishing?

- SPF, DKIM and DMARC
 - DKIM (DomainKeys Identified Mail) is a method to verify that the messages' **content** are trustworthy, meaning that they weren't changed from the moment the message left the initial mail server.



Example DKIM Info

- DKIM-Signature: v=1; a=rsa-sha256;
c=relaxed/relaxed; d=mtu-
edu.20150623.gappssmtp.com;
s=20150623; h=mime-
version:from:date:message-
id:subject:to;

bh=E/HGv2AaUUXSmILKsbffx7dTzBidSxzJBaA
oYV25fNM=;

b=QJTChdp08VJPPXky1XV15P0rfmRBXK
wWfrJTKzz5hY0XKgXGGo+hBoLlY83XUj6R4PTo
R3mpILVIRPqh6dw6yeb528m1f1ZhqQWt/VNDTd
lAGC+3fIurc7QA5WA77etAPfAjpny9VjRT1FR
y79YRMA2GAUhu4KJdB0isFA30P6FAYnkn7iGrY
NS9NnoHYKwrpAc9RWwLvqTkGTroJwnJUW5K0zM
7aWTdCgP8mcc6S4ghdqrOM1N3ao3seMZRXoAIb
aQcKP507YZ60SRSi/wsw9Aa+hH4om2S7BdWG20
zJTigizWnqFJzQdtPxoWrbzrKokWp+G+ruNORV
p9QngiFA==

- This is a version 1 DKIM signature (v=1).
- It was generated with the SHA-256 hash.
- It used relaxed *canonicalization* on the header and contents.
 - Details to come.
- The *Signing Domain Identifier* is listed after the d=.
- The hash was calculated over quite a few header fields: mime-version, from, data, message-id, subject, to.
- The actual hash is after the bh=.
- The big long value after b= is the signature.
- Since there might be multiple keys on file, the selector (after s=) lets the validator find the proper one.

How to Stop Email Phishing?

- SPF, DKIM and DMARC
 - DMARC (Domain-based Message Authentication, Reporting and Conformance) empowers SPF and DKIM by stating a clear policy to send reports about the mail messages statistics gathered by receivers against the specific domain.



Example DMARC Record and Report

- "v=DMARC1;p=reject;pct=100;rua=mailto:postmaster@dmarcdomain.com"
 - This record says:
 - Reject 100% of all unaligned messages. Send a standard aggregate report to the specified address.
 - The report arrives in an XML format, as shown in the snippet at right:
- ```
<record> <row>
 <source_ip>72.150.241.94</source_ip> <count>2</count>
 <policy_evaluated>
 <disposition>none</disposition>
 <dkim>fail</dkim> <spf>pass</spf>
 </policy_evaluated> </row>
 <identifiers>
 <header_from>example.com</header_from> </identifiers> <auth_results>
 <dkim>
 <domain>example.com</domain>
 <result>fail</result>
 <human_result></human_result>
 </dkim> <spf>
 <domain>example.com</domain>
 <result>pass</result> </spf>
 </auth_results> </record>
```

# Reality

- Most people won't have time on email phishing training or have knowledge against email phishing.
- Technologies against email phishing are still under development.
- We have to live with email phishing for a while.

# Recap on Email Phishing

- Email is “ok” for daily, non-sensitive communication.
- It is incredibly easy to forge an email which looks exactly like an legitimate one!
- It is possible to fool and bypass the email filters and other email security measures!
- Be careful when opening email attachments
- Be careful when clicking links in emails
  - If you have to, double check the URL!
- Be aware of phishing text messages, facebook messages...